

Evaluación Parcial 1

El Ministerio de Salud Pública y Asistencia Social de Guatemala (MSPAS), encargado de administrar expedientes clínicos y servicios en línea para la población, sufrió un incidente de seguridad. Durante una auditoría interna se descubrió que:

- El servidor principal del portal de citas médicas tenía configuraciones inseguras: contraseñas débiles, servicios innecesarios activos y sin políticas de bloqueo. No se había aplicado un proceso de hardening.
- Varios trabajadores recibieron correos falsos creados con Zphisher, que imitaban la página oficial del Ministerio para robar credenciales.
- En pruebas de laboratorio, el equipo de seguridad usó BeEF, logrando manipular navegadores de empleados mediante enlaces maliciosos.
- La gerencia recordó el Convenio de Budapest, tratado internacional clave para la cooperación en delitos informáticos transnacionales, señalando que en caso de un ataque desde el extranjero sería el marco legal aplicable.
- En la red interna se detectó que no existía segmentación entre áreas administrativas y que el router inalámbrico usado por visitantes no tenía seguridad avanzada.

Parte Teórica (3 puntos, 0.75 c/u)

Con base en el escenario:

1. Indique dos medidas de hardening que el MSPAS debió aplicar en su servidor principal para evitar que fuera un punto débil.
 1. Primeramente estandarizar un tipo de contraseña, es decir, definir políticas para que las contraseñas que se utilicen cumplan con ciertos requisitos, por ejemplo: tener al menos 8 caracteres, dentro de esos caracteres incluir letras, mayúsculas, minúsculas, números y caracteres especiales. Entonces de esta forma se logra crear una contraseña más robusta. También establecer un tiempo para cambio de contraseñas, puede ser cada 2 meses cambiar la contraseña.
 2. Investigar el modelo del servidor y ver todos los servicios activos que tiene, identificar y dejar activos únicamente los necesarios, ya que entre menos servicios activos menos puntos débiles (o puertas) tendrá el servidor y será más accesible. En cuanto a accesibilidad también definir una política que solo personal autorizado tenga acceso al servidor, esto tanto de manera presencial como de manera remota o por software.
2. Explique cómo Zphisher fue usado en este ataque y qué credenciales buscaba robar a los empleados.

1. Esta herramienta que contiene varias "plantillas" de inicio de sesión de varios sitios web comunes o que las personas acceden de manera frecuente, entonces el como se usó básicamente fue clonar algún sitio por ejemplo Facebook, se enviaba a las víctimas, no revisaban la URL si no que simplemente se iban con la finta e ingresaban sus datos, estas credenciales se le quedaban al atacante y la víctima solo miraba que la página se "recarga" y vuelve a ingresar los datos, solo que a este punto ya fue re dirigido al sitio original. Entonces lo que se buscaba robar en este caso eran las credenciales de los empleados, credenciales de cualquier sitio web que Zphisher tuviera, entre estos están: Facebook, Gmail, Instagram, Discord, entre otros.
3. ¿Qué evidencia mostró el uso de BeEF sobre las vulnerabilidades de los navegadores de los empleados?
 1. Muestra no es necesario que los empleados tengan acceso total a internet, ya que los navegadores son una puerta de acceso para los atacantes, esta puerta de acceso que facilita demasiado el trabajo a los atacantes, entonces demuestra que a los empleados se les tiene que limitar para dar menos espacio a que cometan errores y estos se conviertan en puntos de acceso para los atacantes
4. Si el atacante hubiera operado desde otro país, ¿Cómo apoyaría el Convenio de Budapest a Guatemala en el proceso legal?
 1. Si Guatemala estuviera en el Convenio tendría la posibilidad de pedir ayuda a los demás países, entonces si el ataque hubiera sido desde otro país Guatemala puede solicitar ayuda para capturar al atacante, como también tener en cuenta que si un país está dentro de este convenio quiere decir que tiene leyes que regulan estos delitos.